

www.codelivly.com

DIGITAL FORENSICS HANDBOOK



Digital
Forensics



CODELIVLY
LEARN CYBERSECURITY

TABLE OF CONTENTS

- 1. Introduction**
- 2. Digital Forensics Investigation Methodology**
- 3. Building Your Forensics Toolkit**
 - a. Building a Bootable USB Drive
 - b. Preparing Your Forensics Workstation
 - c. Preparing The Evidence Drive
- 4. Evidence Acquisition**
 - a. Acquiring Volatile Memory
 - b. Acquiring Disk Image
 - c. Acquiring Network Evidence
 - d. Remote Evidence Collection
 - e. Cloud Evidence Collection
- 5. Preserving Evidence.**
- 6. Evidence Analysis.**
 - a. Memory Analysis
 - b. System Storage Analysis
 - c. Log Files Analysis
 - d. Network Evidence Analysis
 - e. Cloud Environment Analysis
- 7. Malware Analysis**
 - a. Static Malware Analysis
 - b. Dynamic Malware Analysis
 - c. Conducting IOCs Research
- 8. Digital Forensics in the Incident Response Cycle**
- 9. Documentation and Reporting**

1.Introduction

In today's digital age, the proliferation of cyber threats and the increasing reliance on digital systems necessitate a robust approach to investigating and mitigating digital crimes. Digital forensics is the practice of collecting, analyzing, and preserving electronic evidence to support the detection and prosecution of cybercriminal activities. This handbook serves as a comprehensive guide for both novice and experienced digital forensics practitioners, providing detailed methodologies and tools required for effective digital forensic investigations.

2. Digital Forensics Investigation Methodology

Understanding the core principles and systematic approaches to digital forensic investigations is crucial. This section covers the structured process that ensures the integrity and admissibility of digital evidence, guiding practitioners through the essential steps of a successful investigation. The digital forensics process may change from one scenario to another, but according to NIST SP800-86, it typically consists of four core steps: collection, examination, analysis, and reporting.

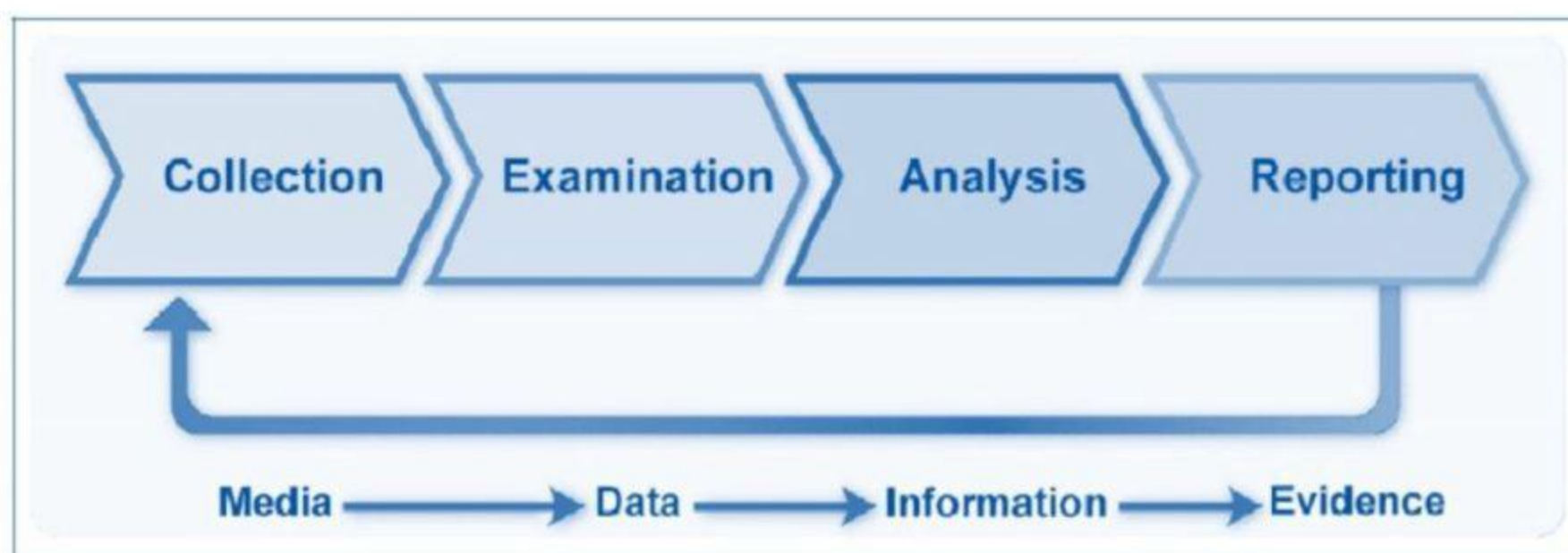


Figure 1. Digital Forensics Process Model - NIST SP800-86

Collection

The collection phase involves acquiring digital evidence, usually by seizing physical assets like computers, hard drives, or phones. It is critical to ensure that data is not lost or damaged during collection (Preservation). You can prevent data loss by copying storage media or creating images of the original. The collection phase starts by identifying the evidence of interest.

Examination

The examination phase involves identifying and extracting data. It can be divided into several steps: prepare, extract, and identify.

When preparing to extract data, you can decide whether to work on a live or dead system. For example, you can power up a laptop to work on it live or connect a hard drive to a lab computer. During the identification step, you need to determine which pieces of data are relevant to the investigation. For example, warrants may restrict an investigation to specific pieces of data.

Analysis

The analysis phase involves using collected data to prove or disprove a case built by the examiners. Here are key questions examiners need to answer for all relevant data items:

- Who created the data
- Who edited the data
- How the data was created
- When these activities occur

In addition to supplying the above information, examiners also determine how the information relates to the case.

Reporting

The reporting phase involves synthesizing the data and analysis into a format that is understandable to laypeople. These reports are essential because they help convey the information so that all stakeholders can understand it.

Note: Chain of custody must be maintained during all phases of the forensics investigation.

3. Building Your Forensics Toolkit

A well-prepared toolkit is fundamental to any forensic investigation. This chapter provides instructions on:

- Building a Bootable USB Drive: Creating a portable and reliable tool for initiating forensic analysis on compromised systems.
- Preparing Your Forensics Workstation: Setting up a dedicated environment optimized for forensic tasks.
- Preparing The Evidence Drive: Ensuring secure and organized storage for collected evidence.

Building a Bootable USB Drive

The main reason for having a bootable USB drive with you is to collect Volatile data from live suspect machines.

1. Wipe the USB drive and overwrite it with Zeros you can use the following command:

- **Windows:** `Format d: /fs:exfat /p:1`
- **Linux:** `dd if=/dev/zero of=/dev/sda bs=1M`

You can replace “d:” and “/dev/sda” with your target drive

2. Download and install/copy your favorite tools to the USB drive

I recommend at least the following tools:

cmd.exe	Diskmap.exe	PSList.exe	Autoruns	Netstat
nbtStat.exe	MD5Deep.exe	PSLoggedon.exe	Wee	Netcat
Now	sha1Deep	PortQry.exe	procmon	Dumpit.exe
Route	sha256deep	PSFile.exe	Procdumb	FTK Imager
Cryptcat.exe	NLSinfo.exe		FLOSS	

Preparing Your Forensics Workstation

You can choose whatever OS you prefer. However, some very nice Linux distributions are tailored for Digital Forensics and are free to use.

For example, you can use the SIFT workstation by SANS which is highly recommended and comes with many of the tools you need preinstalled already.

You can download it from the following link:

<https://www.sans.org/tools/sift-workstation/>

Hint: If you are preparing your own forensics workstation, make sure you verify the hashes of every tool you download before using it.

Preparing The Evidence Drive

Similar to what we have done when preparing the USB drive, the evidence drive (or drives) must be wiped as well, to make sure we have a clean new drive to be used in our evidence collection process.

To Wipe the evidence drive and overwrite it with Zeros you can use the following command:

- **Windows:** `Format d: /fs.exfat /p:1`
- **Linux:** `dd if=/dev/zero of=/dev/sda bs=1M`

You can replace “d:” and “/dev/sda” with your target drive

You can also use the Eraser tool by Heidi, which can be downloaded from:

<https://eraser.heidi.ie/>

4. Evidence Acquisition

Acquiring digital evidence is a delicate process that requires precision and adherence to legal standards. This section delves into various techniques for gathering evidence from different sources:

- **Acquiring Volatile Memory:** Techniques for capturing data stored in volatile memory before it is lost.
- **Acquiring Disk Image:** Methods for creating exact replicas of storage media.

- **Acquiring Network Evidence:** Collecting data from network traffic to identify malicious activities.
- **Remote Evidence Collection:** Strategies for gathering evidence from remote locations.
- **Cloud Evidence Collection:** Navigating the complexities of collecting evidence from cloud-based environments.

Acquiring Volatile Memory

To capture the memory dump of the target machine, follow these straightforward steps:

Open **FTKImager.exe**”

- Choose File - Memory capture
- Choose the target USB drive
- Check (Include pagefile) option
- Check the (Create .AD1 file) option to include deleted files, slack space, and unallocated space drive
- Click Capture memory

You can download FTK Imager from the following link:

<https://www.exterro.com/ftk-product-downloads/ftk-imager-version-4-7-1>

Alternatively, you can use other available tools such as:

- **Dumpit.exe**
- **WinPmem**
- **Ram Capturer**
- **Belkasoft Live RAM tool**

Acquiring Disk Image

Live Imaging:

Live imaging involves capturing an image of a system that has been powered up. There are many tools available to acquire a full disk image from the target suspect machine. Two of the most common tools are FTK Imager and Kroll Artifact Parser and Extractor (KAPE).

They both have straightforward GUI interfaces which can be easily navigated. They are both compatible with most Windows OSs.

You can download FTK Imager from the following link:

<https://www.exterro.com/ftk-product-downloads/ftk-imager-version-4-7-1>

You can download KAPE from the following link:

<https://www.kroll.com/en/insights/publications/cyber/kroll-artifact-parser-extractor-kafe>

If you want to use Linux for imaging you may use the dd command as shown below:

1. Show connected disks:

```
fdisk -l
```

2. Image the selected drive where “/dev/sdb” is the source drive:

```
dd bs=64k if=/dev/sdb of=target.dd
```

3. Verifying the hash of the file:

```
Md5sum usb2gb.dd
```

Dead-box acquisition:

also known as static imaging, involves capturing an image of a system that has been powered down. This method ensures that the data remains unchanged during the imaging process, as the system is in a static state.

When performing Dead-box acquisition, you might want to use a physical write blocker such as (Tableau Forensic Bridge Kit). It is a physical hardware that sits between the evidence drive and the system performing the acquisition which only allows data to be passed in a one-way direction from the evidence disk to the analysis workstation.

To create a disk image using FTK Imager click on File – Create Disk Image – Select Physical Drive – Choose E01 or dd as the Destination type – and specify the destination Folder and File name.

Virtual Systems Acquisition:

To acquire the running memory from a VMware instance you need to collect the following files:

1. Virtual Memory (VMEM) file.
2. VMware Suspended State (VMSS) file.

You can combine both files into a single file by the following steps:

1. Pause the VMware instance.
2. Create a “.dmp” file by running the following command:

```
C:\Program Files (x86)\VMware\VMware Workstation>vmss2core.exe  
suspect.vmss suspect.vmem
```

To acquire a full disk image from a VMware instance, follow the steps below:

1. Pause the VMware instance.
2. Copy the “.vmdk” file and mount it to a new drive.

Acquiring Network Evidence

You may want to inspect the logs from some of the following devices for network-related evidence:

- Firewalls
- Web Proxy Servers
- Web Application Firewalls
- NetFlow traffic from network devices such as Routers and switches.

You can also inspect the network traffic of the suspect machine by establishing a packet capture using tools like Wireshark, WinPcap, or tcpdump.

To download Wireshark:

<https://www.wireshark.org/download.html>

To download tcpdump: _____

<http://www.tcpdump.org/>

To download WinPcap:

<https://www.winpcap.org>

Remote Evidence Collection

This method includes data which is collected from systems that are suspected of being compromised. Our goal is to collect high-value data in a central location where it can be indexed and further analyzed.

These are some of the ways that can utilized for remote evidence collection:

- Endpoint Detection and Response (EDR) if available.
- Velociraptor (<https://docs.velociraptor.app>)
- WinPmem (<https://github.com/Velocidex/WinPmem>)

Cloud Evidence Collection

Amazon Web Services (AWS)

1. Create EC2 volume snapshot.
2. AWS will always assign the root drive (C:\) to /dev/sda1, that is if you only want to collect the root drive.
3. Under the Actions tab click Create Snapshot.
4. Then you may Create a new volume using the snapshot you have taken. This can be done by clicking on the Action tab, then “Create volume from snapshot” option.

To acquire a memory dump of an instance in AWS, simply switch the EC2 instance to Hibernation mode and copy the “hyberfil.sys” file. Alternatively, you can also use any of the traditional OS memory acquisition methods explained earlier in this document.

Microsoft Azure

The acquisition process of Microsoft Azure VMs is pretty similar to AWS, with some minor differences. It includes the following steps:

1. Create an Azure VM snapshot of the target machine (Snapshot page – Create Snapshot)
2. Select Full snapshot
3. Select the Source disk

To export the VM snapshot directly:

1. Go to Settings
2. Select Export Snapshot
3. A URL with the virtual hard disk “.VHD” file will be generated

4. Download the “.VHD” file for further investigation

To capture the memory dump of an Azure VM, you may connect to it via SSH or RDP. Alternatively, you can utilize a built-in service called “Bastion” which is straightforward to use.

Google Cloud Platform (GCP)

GCP is also similar to AWS and Azure. Follow the steps below to collect the evidence from the Compute Engine instance:

1. Create a snapshot by navigating to Storage – Snapshots – Select Complete snapshot
2. Create a new instance and select the created snapshot as a Disk Source
3. Use the dd command to extract the disk image.

To acquire a memory dump from a GCP instance:

1. Create a service account via the GCP IAM component
2. Specify: Compute Admin – Storage Object Admin privileges
3. Connect to the target instance using GCP Cloud Shell using the service account you created or via RDP, then Create a memory dump using winpmem.exe or dumpit.exe

5. Preserving Evidence

Preservation of evidence is critical to maintaining its integrity and admissibility in court. The original evidence must be kept in its original state without any modifications and it should be kept in a safe place throughout the investigation process.

In addition, proper Chain of Custody must be followed and documented whenever someone handles the evidence. ***“The chain of custody is the most critical process of evidence documentation. It is a must to assure the court of law that the evidence is authentic, i.e., it is the same evidence seized at the crime scene. It was, at all times, in the custody of a person designated to handle it and for which it was never unaccounted”*** By NIST.

In summary, evidence integrity is the cornerstone of a successful digital forensics investigation. It safeguards the reliability and trustworthiness of digital evidence, protects the rights of individuals involved in a case, and upholds the integrity of the criminal justice

A sample of a Chain of Custody document is shown below:

PROPERTY / EVIDENCE CHAIN OF CUSTODY FORM				Print Form
Case Name:		Reason Obtained:		
Case Number:				
Item Number:	Evidence Type / Manufacturer:	Model Number:	Serial Number:	
Content Owner / Title:		Content Description:		
Content Owner Contact Information:				
Forensic Agent:	Creation Method:	HASH Value:	Creation Date/Time:	
Forensic Agent Contact Information:				

CHAIN OF CUSTODY				
Tracking Number	Date / Time	Released By	Received By	Reason for Change
	Date:	Name / Title	Name / Title	
	Time:	Signature	Signature	
	Date:	Name / Title	Name / Title	
	Time:	Signature	Signature	
	Date:	Name / Title	Name / Title	
	Time:	Signature	Signature	

Item Number: _____

Page: 1 of _____

Sample of a Chain of Custody document
Source: <https://rossum.ai/use-cases/miscellaneous/chain-of-custody-form/>

6. Evidence Analysis

Analyzing the collected evidence is where the investigative insights are derived. This section covers various types of analysis, including:

- Memory Analysis: Examining data stored in RAM for traces of malicious activity.
- System Storage Analysis: Analyzing data stored on hard drives and SSDs.
- Log Files Analysis: Interpreting system and application logs to reconstruct events.
- Network Evidence Analysis: Investigating network traffic to identify patterns and anomalies.
- Cloud Environment Analysis: Assessing evidence obtained from cloud services.

Memory Analysis

During memory analysis, you might find interesting valuable data and information related to your investigation. This includes but is not limited to:

- Strings
- Running processes
- Loaded DLLs
- Device drivers
- Registry keys
- Network connections
- Command history

SANS lays out a six-step methodology for Memory Analysis, which includes the following steps:

1. Identify Rogue Processes
2. Analyze Process DLLs and handles
3. Review Network Artifacts
4. Look for evidence of code injection
5. Check for signs of a rootkit
6. Dump suspicious processes and drivers

Various free and commercial tools exist for conducting memory analysis. In this document, we will explore three of the most well-known free tools which are **Strings**, **Volatility**, and **Autopsy**.

Strings

Strings is a command-line tool that can be used to search for valuable text information in the memory dump file. This could include suspect names, usernames, IPs, files, hostnames, application names, and more.

It can be downloaded and installed from the following link:

<https://docs.microsoft.com/en-us/sysinternals/downloads/strings>

Below is an example of using Strings to dump all the strings in a memory dump to a text file via the command line:

```
strings "D:\memdump.mem" | t_wtee "D:\strings.txt"
```

The “w_wtee” option is used to display the output and write it to the text file

Apart from manually searching the Strings output, here are some common String searches that might be useful in your investigation:

“To find IP addresses, use the strings command with the following parameters:

```
strings pagefile.sys | grep -oE "\b([0-9]{1,3}\.){3}[0-9]{1,3}\b"
```

To find URIs and URLs, use http or https:

```
strings pagefile.sys | grep "^https?:://" | sort | uniq | less
```

To find email addresses, use the following command:

```
strings pagefile.sys | grep '([[:alnum:]]_.-){1,64}+@[[:alnum:]]_.-  
]{2,255}+?\.[[:alpha:]]{2,4})'
```

You can replace “grep” with “Select-String” if you are using Windows OS.

Another convenient option in strings is -n which allows you to specify the minimum number of characters for each string to be extracted.

Volatility

Volatility is an advanced open-source memory forensics command-line-based tool, which is available to be downloaded at:

<https://github.com/volatilityfoundation/volatility>

We will explore some of the common useful commands in Volatility below:

1. To display image information:

```
vol.py -f "/path/to/file" imageinfo
vol.py -f "/path/to/file" kdbgscan
```

2. To display process information:

```
vol.py -f "/path/to/file" --profile <profile> pslist
vol.py -f "/path/to/file" --profile <profile> psscan
vol.py -f "/path/to/file" --profile <profile> pstree
vol.py -f "/path/to/file" --profile <profile> psxview
```

3. To dump a specific process:

```
vol.py -f "/path/to/file" --profile <profile> procdump -p <PID> --dump-dir="/path/to/dir"
```

4. To check the DLL files associated with a process:

```
vol.py -f "/path/to/file" --profile <profile> dlllist -p <PID>
```

5. To display command line history:

```
vol.py -f "/path/to/file" --profile <profile> cmdline
vol.py -f "/path/to/file" --profile <profile> cmdscan
vol.py -f "/path/to/file" --profile <profile> consoles
```

6. To display network information:

```
vol.py -f "/path/to/file" --profile <profile> netscan
vol.py -f "/path/to/file" --profile <profile> netstat
```

7. Registry hives list:

```
vol.py -f "/path/to/file" --profile <profile> hivescan
vol.py -f "/path/to/file" --profile <profile> hivelist
```

8. To display ranges within memory that may contain injected code:

```
vol.py -f "/path/to/file" --profile <profile> malfind
```

Note: The examples below apply to Volatility version 2. For Volatility version 3 syntax, you may check out the following cheatsheet:

<https://blog.onfvp.com/post/volatility-cheatsheet/>

For more details and usage examples of Volatility, here are some useful resources:

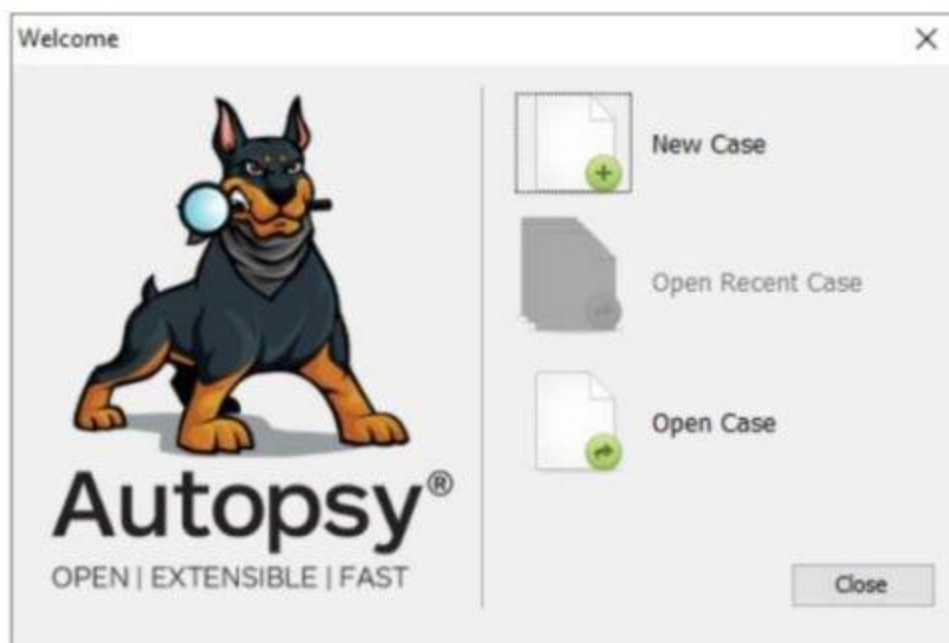
- <https://blog.onfvp.com/post/volatility-cheatsheet/>
- <https://www.andreafortuna.org/2017/06/25/volatility-my-own-cheatsheet-part-1-image-identification/>
- <https://blog.onfvp.com/post/volatility-cheatsheet/>
- <https://memoryforensic.com/memory-forensics-cheat-sheets/>

Volatility Workbench is a GUI tool for Volatility with the same functionality as the original CLI tool. *You can download it here:*

<https://www.osforensics.com/tools/volatility-workbench.html>

Autopsy

Another great GUI tool we must mention here is Autopsy. Autopsy® is the premier end-to-end open-source digital forensics platform. It can be used in memory analysis, disk image analysis, log analysis, registry analysis, and many more use cases.



You Can download it from here:

<https://www.autopsy.com/download/>

To Start a new Digital Forensics case in Autopsy:

<https://www.youtube.com/watch?v=fEqx0MeCCHg>

SANS Memory Forensics Cheat Sheet:

<https://www.sans.org/posters/dfir-memory-forensics/>

System Storage Analysis

Autopsy can be very helpful in examining any of the following:

- Web artifacts (Downloads and history)
- Email artifacts
- Attached devices
- Recovering deleted files
- Timeline analysis
- keyword searches

Master Files Table Analysis (\$MFT)

MFT can be found within the root directory of the filesystem. To analyze the MFT table you can use the MFT Explorer tool by Eric Zimmerman.

Eric Zimmerman has created a suite of tools for carving and analyzing data available at:

<https://ericzimmerman.github.io/#!index.md>.

SANS cheat sheet for the tools is also available at:

<https://www.sans.org/posters/eric-zimmerman-tools-cheat-sheet/>

Prefetch Analysis

Prefetch files are beneficial for us to find out if specific executables have run in the past. You can use another tool by Eric Zimmerman called Prefetch Parser (PECmd.exe)/ Prefetch files are created in “C:\Windows\Prefetch” directory.

For a deep dive into Prefetch analysis, check out the following YouTube video:

https://www.youtube.com/watch?v=f4RArR_3zcs

Registry Analysis

The registry hives are located in “%SystemRoot%\system32\config” folder. They include 5 root keys:

- HKEY_LOCAL_MACHINE
 - o SAM
 - o Security

- o Software
- o System
- HKEY_CURRENT_USER
 - o Ntuser.dat
 - o Ntuser.dat.log
- HKEY_USERS
 - o Default
 - o Default.log
 - o Default.sav
- HKEY_CLASSES_ROOT
- HKEY_CURRENT_CONFIG
 - o System
 - o System.alt
 - o System.log
 - o System.sav

File Name	Associated Hive	Information Contained
Software	HKEY_LOCAL_MACHINE\SOFTWARE	Information about all the software items in the system, Windows performance parameters and the default Windows settings.
System	HKEY_LOCAL_MACHINE\SYSTEM	Information about all the hardware items in the system.
Sam	HKEY_LOCAL_MACHINE\SAM	Information about the Security Accounts Manager service.
Security	HKEY_LOCAL_MACHINE\SECURITY	Information about security. Neither of Security and SAM, can be viewed using Regedit, unless you reset the permissions.
Default	HKEY_USERS\DEFAULT	Default user settings. But the Ntuser.dat file corresponding to the currently logged-on user overrides the default user settings.
Userdiff	Not associated with any hive.	Information about the corresponding subkeys in the HKEY_USERS Hive for each registered user.

To examine the registry hives, we recommend using the “Registry Explorer” tool by Eric Zimmerman:

<https://f001.backblazeb2.com/file/EricZimmermanTools/net6/RegistryExplorer.zip>

For more information and documentation on Registry Explorer:

<https://aboutdfir.com/toolsandartifacts/windows/registry-explorer-recmd/>

Eric Zimmerman's tools Cheat Sheet

<https://www.sans.org/posters/eric-zimmerman-tools-cheat-sheet/>

Windows Registry Analysis 101:

<https://www.forensicfocus.com/articles/windows-registry-analysis-101/>

SANS Registry Cheat Sheet

<https://tinyurl.com/y7ncd2vp>

Log Files Analysis

Windows event log analysis is a crucial component of digital forensics that involves examining the event logs generated by the Windows operating system. These logs provide a detailed record of system, application, and security-related events, which can offer valuable insights into user activities, system changes, and potential security incidents.

Types of Windows Event Logs

1. **System Logs** : Record events related to the operating system and its components. This includes hardware changes, driver issues, and system startup and shutdown events.
2. **Application Logs** : Contain events logged by applications running on the system. This can include errors, warnings, and informational messages from software applications.
3. **Security Logs** : Capture security-related events, such as login attempts, logoffs, account management activities, and resource access. These logs are essential for identifying unauthorized access and other security incidents.

Key Elements in Event Log Analysis

1. **Event IDs**: Each event log entry is assigned a unique identifier (Event ID) that describes the type of event. Familiarity with common Event IDs helps investigators quickly identify significant events.
2. **Time Stamps**: Time stamps are crucial for constructing a timeline of events, correlating activities, and understanding the sequence of actions in the system.
3. **User Information**: Logs often include the username associated with an event, providing insights into who performed specific actions.

4. **Event Source:** Indicates the application or system component that generated the event, helping to identify the origin of specific activities.

Several tools can assist in analyzing Windows event logs, including:

- **Event Viewer:** A built-in Windows utility that allows users to view and analyze event logs.
- **Log Parser:** A powerful tool from Microsoft for querying and analyzing log files, including event logs.

Event logs are located in the logs directory "C:\Windows\System32\winevt\logs".

Here is a list of some of the common event IDs which could be useful in your investigation: